

redis加固

笔记本：	应用服务加固		
创建时间：	2018/11/2 21:25	更新时间：	2018/11/3 22:43
作者：	苏醒		
URL：	https://help.aliyun.com/knowledge_detail/37447.html?spm=a2c4g.11186623.4.6.43bc1559JQt8zS		

一.背景描述

1.漏洞描述

Redis 因配置不当存在未授权访问漏洞，可以被攻击者恶意利用。

在特定条件下，如果 Redis 以 root 身份运行，黑客可以给 root 账号写入 SSH 公钥文件，直接通过 SSH 登录受害服务器，从而获取服务器权限和数据。一旦入侵成功，攻击者可直接添加账号用于 SSH 远程登录控制服务器，给用户的 Redis 运行环境以及 Linux 主机带来安全风险，如删除、泄露或加密重要数据，引发勒索事件等。

2.受影响范围

在 Redis 客户端，尝试无账号登录 Redis：

```
root@kali:~# redis-cli -h 10.16.10.2
```

```
redis 10.16.10.2:6379> keys *
```

```
1) "1"
```

从登录结果可以看出，该 Redis 服务对公网开放，且未启用认证。

二.修复方案

1.网络层加固

指定 Redis 服务使用的网卡

默认情况下，Redis 监听 **127.0.0.1**。如果仅仅是本地通信，请确保监听在本地。

这种方式可以在一定程度上缓解 Redis 未授权访问的风险（例外情况下，如果 Redis 以 root 用户运行，攻击者借助已有的 webshell，就可以利用该 Redis 来反弹 shell 以实现提权）。

/etc/redis/redis.conf

在 **redis.conf** 文件中找到 **# bind 127.0.0.1**，将前面的 # 去掉，然后保存。

注意：

该操作需要重启 Redis 才能生效。

修改后只有本机才能访问 Redis，也可以指定访问源 IP 来访问 Redis。

1. **bind 192.168.1.100 10.0.0.1**

2.设置防火墙策略

如果正常业务中 Redis 服务需要被其他服务器来访问，可以通过 iptables 策略，仅允许指定的 IP 来访问 Redis 服务。

1. `iptables -A INPUT -s x.x.x.x -p tcp --dport 6379 -j ACCEPT`

3.账号与认证

设置访问密码

在 `redis.conf` 中找到 `requirepass` 字段，去掉其注释，并在后面填上需要的密码。Redis 客户端也需要使用此密码来访问 Redis 服务。

打开 `/etc/redis/redis.conf` 配置文件:

1. `requirepass !QE%^E3323BDWEwww1839`

确保密码的复杂度，配置完毕后重启服务即可生效。

4.服务运行权限最小化

修改 Redis 服务运行账号

请以较低权限账号运行 Redis 服务，并禁用该账号的登录权限。以下操作创建了一个无 home 目录权限，且无法登录的普通账号：

1. `useradd -M -s /sbin/nologin [username]`

注意：该操作需要重启 Redis 才能生效。

5.服务精细化授权

隐藏重要命令

Redis 无权限分离，其管理员账号和普通账号无明显区分。攻击者登录后可执行任意操作，因此需要隐藏以下重要命令：`FLUSHDB`，`FLUSHALL`，`KEYS`，`PEXPIRE`，`DEL`，`CONFIG`，`SHUTDOWN`，`BGREWRITEAOF`，`BGSAVE`，`SAVE`，`SPOP`，`SREM`，`RENAME`，`DEBUG`，`EVAL`。

另外，在 Redis 2.8.1 及 Redis 3.x（低于 3.0.2）版本下存在 EVAL 沙箱逃逸漏洞，攻击者可通过该漏洞执行任意 Lua 代码。

下述配置将 `config/flushdb/flushall` 设置为空，即禁用该命令；也可设置为一些复杂的、难以猜测的名字。

1. `rename-command CONFIG ""`
2. `rename-command flushall ""`

3. `rename-command flushdb ""`

4. `rename-command shutdown shutdown_test`

保存后，执行 `/etc/init.d/redis-server restart` 重启生效。

6.安全补丁

定期关注最新软件版本，并及时升级 Redis 到最新版，防止新漏洞被恶意利用。

安装：

下载安装包

wget <http://download.redis.io/releases/redis-4.0.2.tar.gz>

解压安装包并安装

tar xzf redis-4.0.2.tar.gz

cd redis-4.0.2

make

make install

Redis没有其他外部依赖，安装过程很简单。编译后在Redis源代码目录的src文件夹中可以找到若干个可执行程序，安装完后，在/usr/local/bin目录中可以找到刚刚安装的redis可执行文件。

启动和停止Redis

启动Redis

直接启动

直接运行redis-server即可启动Redis

[root@localhost bin]# redis-server

mkdir /usr/redis

cp redis-server /usr/redis

cp redis-benchmark /usr/redis

cp redis-cli /usr/redis

cp redis.conf /usr/redis

cp redis.conf /etc/redis

cd /usr/redis

3、启动Redis服务。

\$ redis-server redis.conf

4、然后用客户端测试一下是否启动成功。

\$ redis-cli

redis> set foo bar

OK

redis> get foo

"bar"

-

-

现在也可以使用下面的命令来启动和关闭Redis了

```
/etc/init.d/redis_6379 start  
/etc/init.d/redis_6379 stop
```

Redis随系统自动启动，这还需要对Redis初始化脚本进行简单修改，执行命令：

```
vim /etc/init.d/redis_6379
```

在打开的redis初始化脚本文件头部第四行的位置，追加下面两句

```
# chkconfig: 2345 90 10 # description: Redis is a persistent key-value database
```

上图红色框中就是追加的两行注释，添加完毕后进行保存，即可通过下面的命令将Redis加入系统启动项里了

```
//设置开机执行redis脚本  
chkconfig redis_6379 on
```

通过上面的操作后，以后也可以直接用下面的命令对Redis进行启动和关闭了，如下

```
service redis_6379 start  
service redis_6379 stop
```